

PENETRATION TESTING REPORT

W4-PM-FINAL | CYBERSECURITY | NETWORKWALKS

Pentester Name (Cybersecurity Professional)	Kavitha A L
Program/Batch	B083-Networkwalks
Date	01 October 2026
Modules completed	M1 – Initial Access M2 – Data Extraction (Cracking) M3 – Attack: Critical Data Exposure M4 – Penetration Testing Report
Client/Target	Mediroza General Hospital https://medirozahospital.com
Permission secured from client?	Yes — written authorisation granted by Networkwalks
Phases covered	Phase 1: Reconnaissance & Initial Access Phase 2: Data Extraction & Password Cracking Phase 3: Post-Exploitation / Sensitive Data Exposure Phase 4: Reporting

1. Liability Disclaimer

I have performed these activities only on the systems & devices where I had secured written permission or the devices/systems that I own myself. All these materials are for education and research purpose only. Do not use anything from here to break the law. The instructor, the authors and Networkwalks are not responsible for what i do with this knowledge. Every action i take is my own responsibility. Misuse can lead to criminal charges, heavy fines, loss of your job and a permanent record. In most countries unauthorised access is a crime even when nothing is damaged.

2. Executive Summary

This report presents the results of a five-day black-box penetration test conducted against the Mediroza General Hospital web application. The assessment focused on identifying security weaknesses that could enable unauthorised access to confidential patient reports and sensitive organisational information. The testing covered reconnaissance, entry-point and authentication analysis, controlled exploitation, file protection assessment, and identification of further data exposure. The report documents the identified security issues, supporting evidence, associated risk levels, and recommended remediation actions.

3. Scope and Methodology

Target: <https://medirozahospital.com>

Testing Type: Full black-box penetration test. Testing was limited to the target domain only. No social engineering, no denial-of-service testing, and no testing outside the agreed scope was performed. Written authorisation for this engagement was provided by the client via Networkwalks.

I followed a structured black-box penetration testing methodology consisting of four phases.

- Reconnaissance: Passive information gathering using publicly available information and web-based tools.
- Vulnerability Identification: Analysing the application behaviour to find weaknesses in authentication and input handling.
- Exploitation: Demonstrating the real impact of each vulnerability through controlled exploitation.
- Documentation: Recording all findings, evidence, and remediation recommendations in this report.

The table below lists each tool used in this report and its purpose.

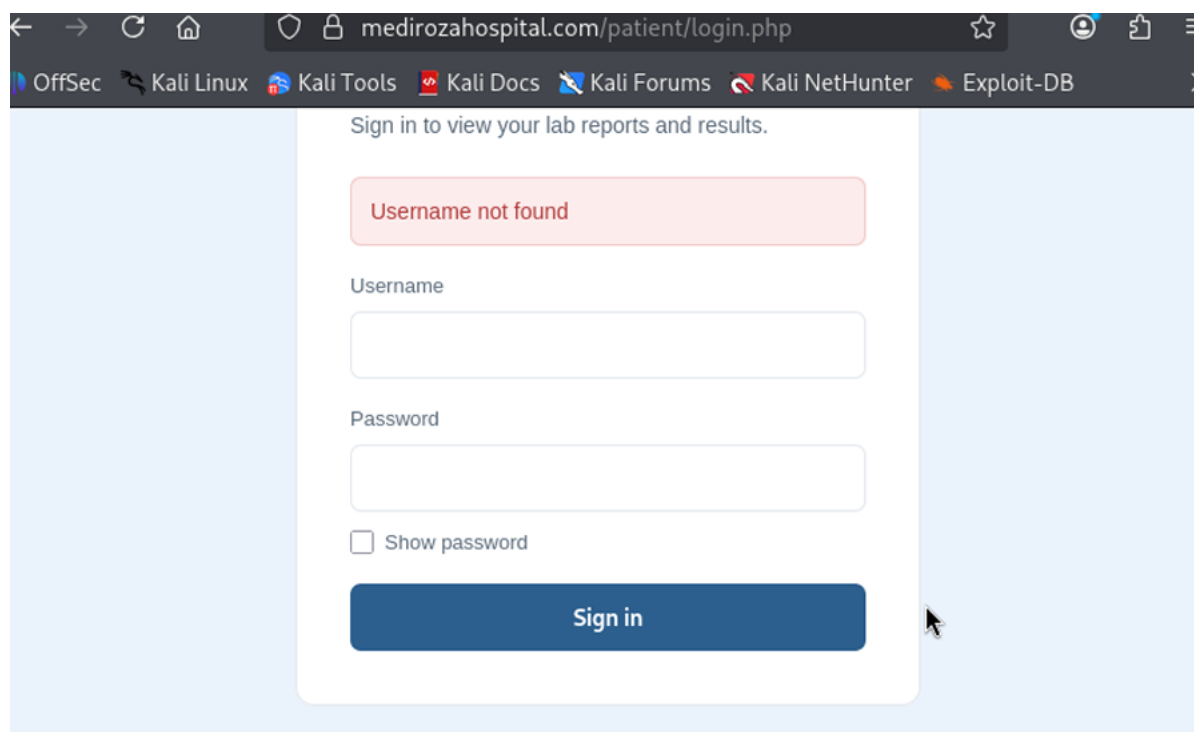
Tool	Purpose
nmap / gobuster	Network and directory/content discovery during reconnaissance
curl -I	Read the HTTP response headers of the website.
wafw00f	Detect whether a Web Application Firewall protects the site.
dnsrecon	Enumerate all DNS records (NS, MX, SPF, TXT, SRV).
NetworkWalks Hash Calculator	PDF key/hash generation
NetworkWalks Password Cracker	Wordlist-based document password testing
qpdf	Decrypting password-protected PDF files after cracking
wget	Downloading files from the web server

4. Findings and Proof of Exploitation

4.1 Username Enumeration

Username enumeration occurs when a login page reveals whether a username exists or not by showing different error messages for a wrong username versus a wrong password. A secure login should always show the same generic message for both cases to prevent an attacker from confirming valid usernames.

Patient portal login page opened and tested the error messages by entering different username and password.

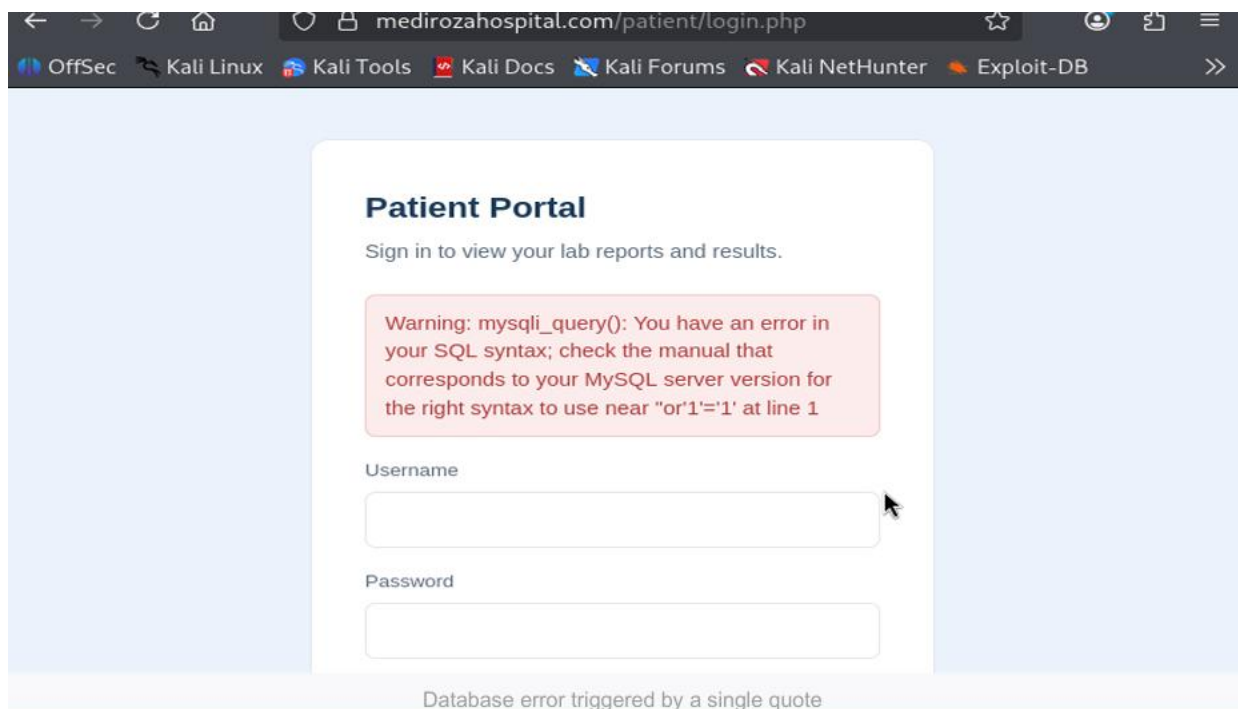


SQL injection is a vulnerability where an application places user input directly inside a database query without sanitising it first. An attacker can insert SQL code into the input field to change the behaviour of the query. In this case, I was able to comment out the password check entirely and log in as admin without knowing the password.

```
username: admin' password:
test123

RESPONSE: Warning: mysqli_query(): You have an error in your SQL syntax;
check the manual that corresponds to your MySQL server version for the
right syntax to use near ''' at line 1
```

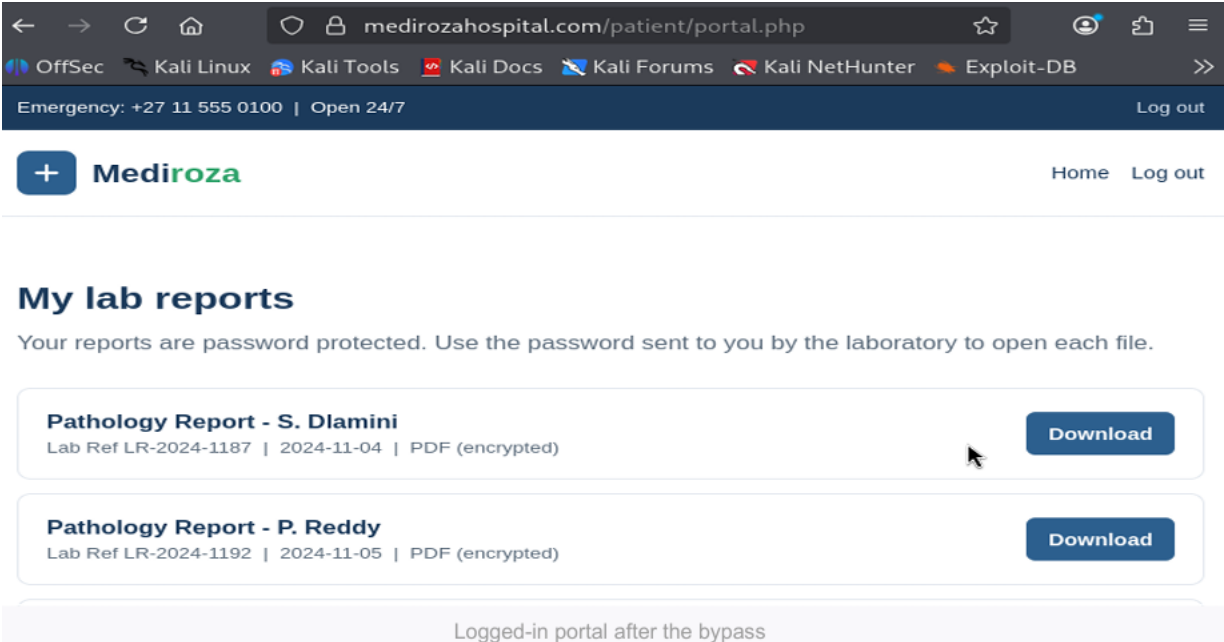
I tested the username field for SQL injection by typing a single quote.



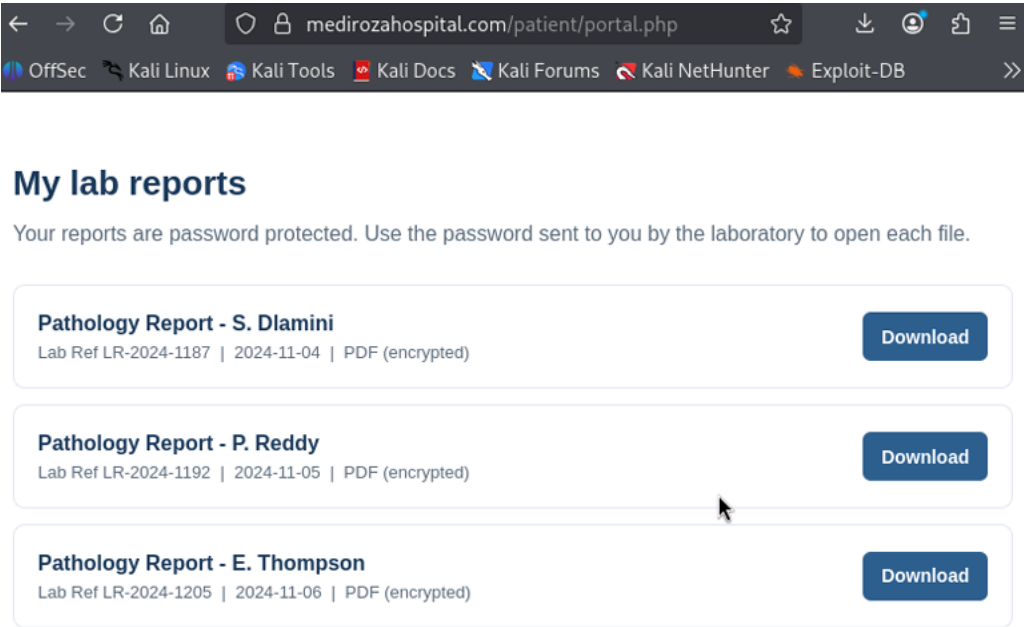
The database error confirmed the field was injectable. The application was building its SQL query like this behind the scenes.

```
SELECT * FROM users WHERE username='admin'
```

The password check is ignored completely. The query returns the admin row and I am logged in.



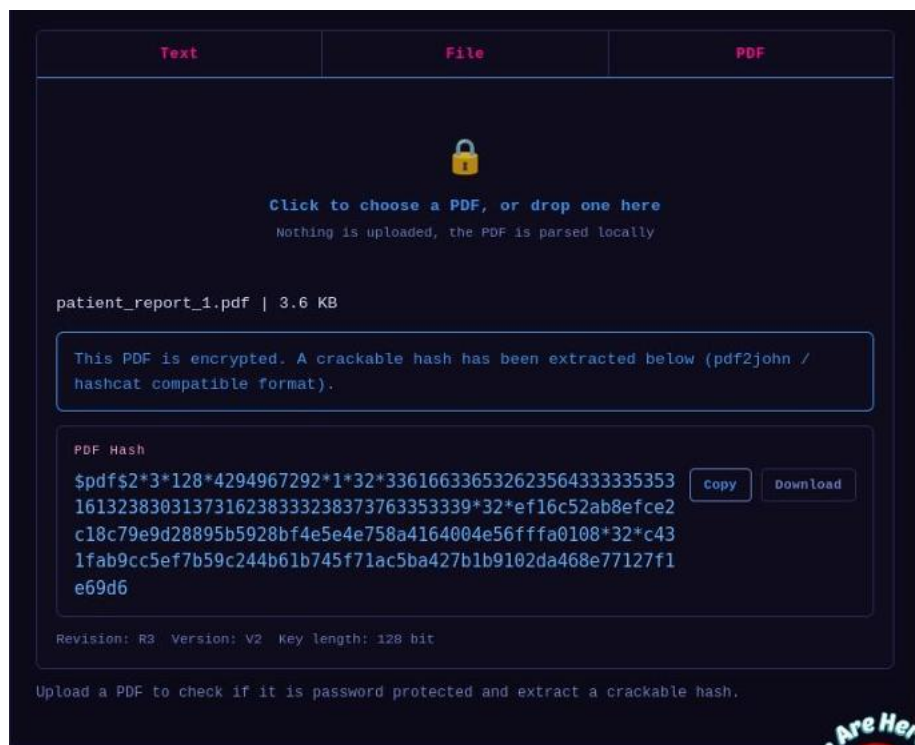
After gaining unauthorised access to the portal through SQL injection, I found three patient lab report PDFs available for download. These are confidential medical documents that should only be accessible to the named patients and their doctors.



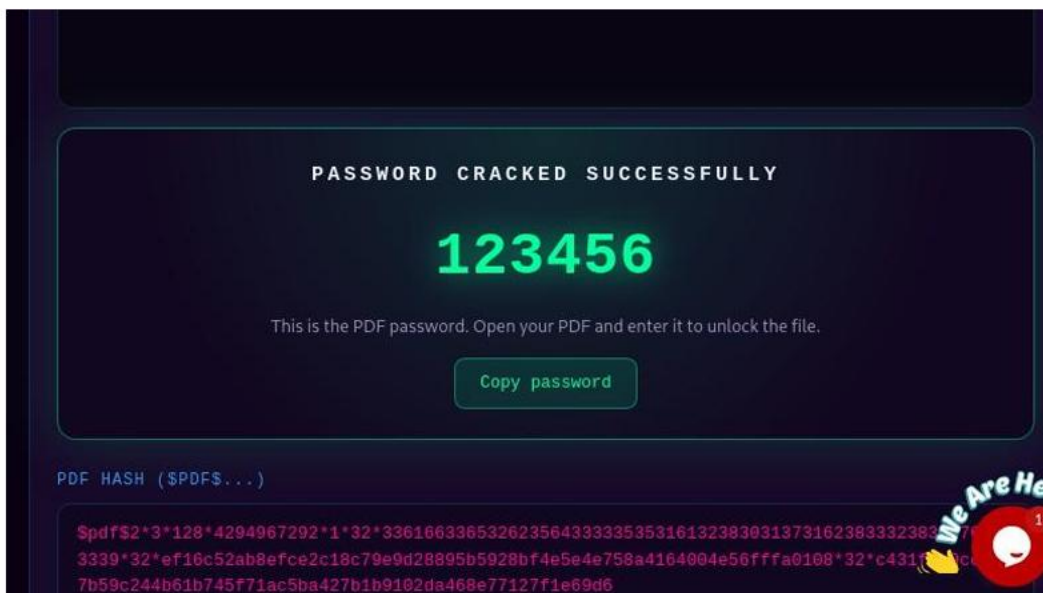
Downloaded all three files and each files were password protected before proceeding.

All three PDFs were password protected. However the passwords were weak and appeared in commonly available password wordlists, making them trivial to crack using automated tools. Using simple passwords on sensitive medical documents does not provide meaningful protection.

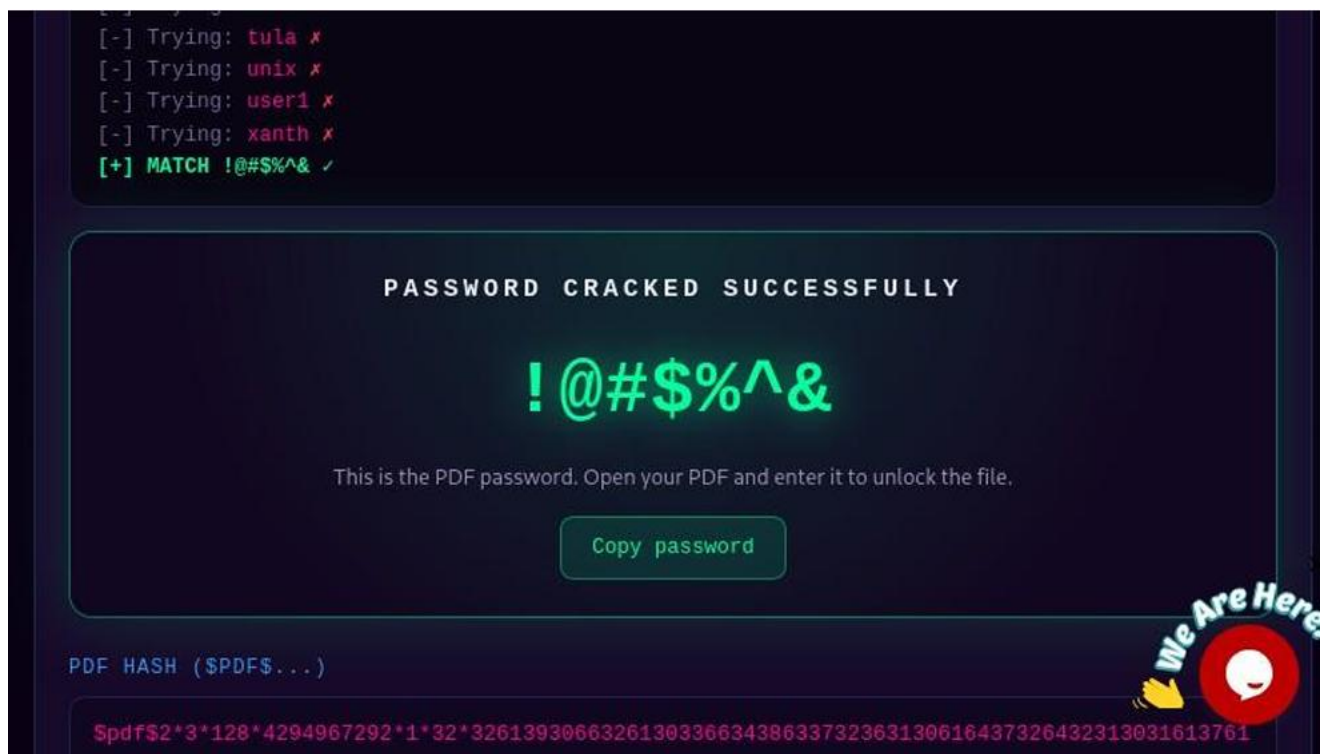
Networkwalks Hash Calculator to extract a crackable hash from each PDF, then ran each hash through the Networkwalks Password Cracker.



Reports 1 and 2 cracked immediately using the built-in 100-word default wordlist.



Report 3 did not crack with the built-in list. I switched to a larger wordlist (the JTR default password list) and ran the attack again.



Sensitive Metadata in Patient PDF Files

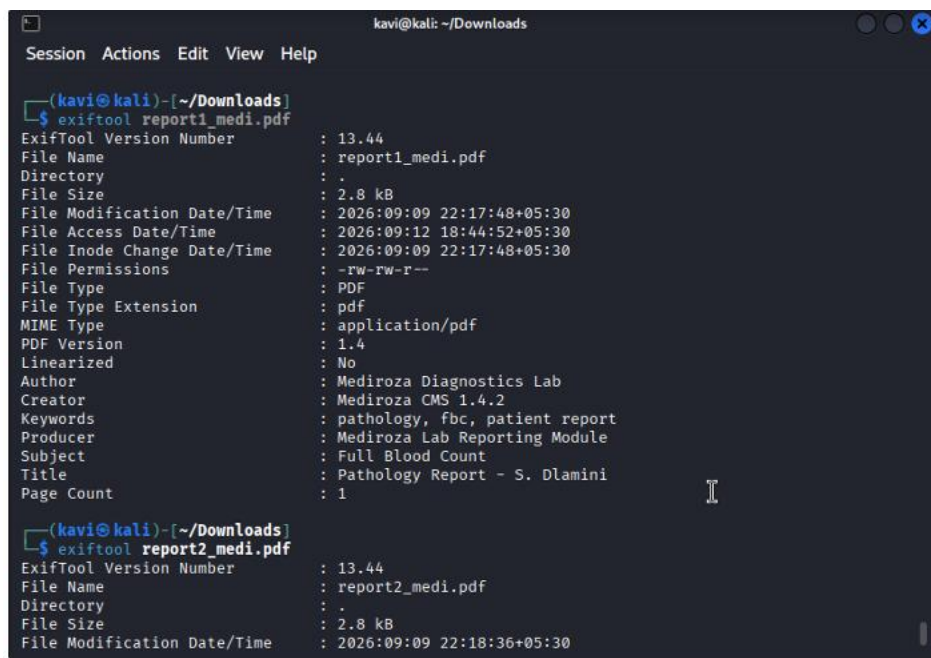
PDF files store hidden metadata such as the author name, creation date, and custom comments. This metadata is not visible when simply reading the document but can be extracted using tools like exiftool.

In this case, report 3 contained an internal staff comment left by the IT administrator that pointed directly to a confidential backup file on the server.

Decrypted report 3 using qpdf so that exiftool could read all metadata fields. A locked PDF only shows the encryption type.

```
qpdf --password='!@#$$%^&' --decrypt patient_report_3.pdf report3_open.pdf
```

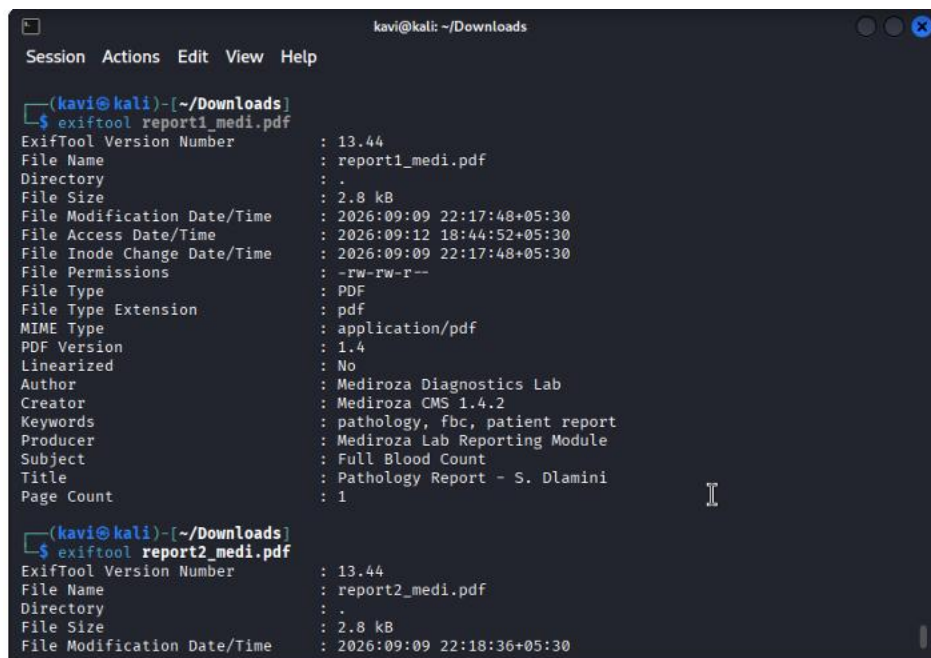
Run exiftool on the unlocked file.



```
kavi@kali: ~/Downloads
Session Actions Edit View Help

(kavi@kali)~[~/Downloads]
$ exiftool report1_medi.pdf
ExifTool Version Number      : 13.44
File Name                    : report1_medi.pdf
Directory                    : .
File Size                    : 2.8 kB
File Modification Date/Time  : 2026:09:09 22:17:48+05:30
File Access Date/Time       : 2026:09:12 18:44:52+05:30
File Inode Change Date/Time  : 2026:09:09 22:17:48+05:30
File Permissions             : -rw-rw-r--
File Type                    : PDF
File Type Extension          : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.4
Linearized                   : No
Author                       : Mediroza Diagnostics Lab
Creator                      : Mediroza CMS 1.4.2
Keywords                     : pathology, fbc, patient report
Producer                     : Mediroza Lab Reporting Module
Subject                      : Full Blood Count
Title                        : Pathology Report - S. Dlamini
Page Count                   : 1

(kavi@kali)~[~/Downloads]
$ exiftool report2_medi.pdf
ExifTool Version Number      : 13.44
File Name                    : report2_medi.pdf
Directory                    : .
File Size                    : 2.8 kB
File Modification Date/Time  : 2026:09:09 22:18:36+05:30
```



```
kavi@kali: ~/Downloads
Session Actions Edit View Help

(kavi@kali)~[~/Downloads]
$ exiftool report1_medi.pdf
ExifTool Version Number      : 13.44
File Name                    : report1_medi.pdf
Directory                    : .
File Size                    : 2.8 kB
File Modification Date/Time  : 2026:09:09 22:17:48+05:30
File Access Date/Time       : 2026:09:12 18:44:52+05:30
File Inode Change Date/Time  : 2026:09:09 22:17:48+05:30
File Permissions             : -rw-rw-r--
File Type                    : PDF
File Type Extension          : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.4
Linearized                   : No
Author                       : Mediroza Diagnostics Lab
Creator                      : Mediroza CMS 1.4.2
Keywords                     : pathology, fbc, patient report
Producer                     : Mediroza Lab Reporting Module
Subject                      : Full Blood Count
Title                        : Pathology Report - S. Dlamini
Page Count                   : 1

(kavi@kali)~[~/Downloads]
$ exiftool report2_medi.pdf
ExifTool Version Number      : 13.44
File Name                    : report2_medi.pdf
Directory                    : .
File Size                    : 2.8 kB
File Modification Date/Time  : 2026:09:09 22:18:36+05:30
```

```
kavi@kali: ~/Downloads
Session Actions Edit View Help
(kavi@kali)~[~/Downloads]
$ exiftool report2_medi.pdf
ExifTool Version Number      : 13.44
File Name                    : report2_medi.pdf
Directory                    : .
File Size                    : 2.8 kB
File Modification Date/Time   : 2026:09:09 22:18:36+05:30
File Access Date/Time        : 2026:09:12 18:44:58+05:30
File Inode Change Date/Time   : 2026:09:09 22:18:36+05:30
File Permissions              : -rw-rw-r--
File Type                    : PDF
File Type Extension           : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.4
Linearized                   : No
Author                       : Mediroza Diagnostics Lab
Creator                      : Mediroza CMS 1.4.2
Keywords                     : pathology, lipids, patient report
Producer                     : Mediroza Lab Reporting Module
Subject                       : Lipid Profile
Title                        : Pathology Report - P. Reddy
Page Count                   : 1

(kavi@kali)~[~/Downloads]
$ exiftool report3_medi.pdf
ExifTool Version Number      : 13.44
File Name                    : report3_medi.pdf
Directory                    : .
File Size                    : 2.9 kB
File Modification Date/Time   : 2026:09:12 18:51:58+05:30
File Access Date/Time        : 2026:09:12 18:51:58+05:30
```

```
(kavi@kali)~[~/Downloads]
$ exiftool report3_medi.pdf
ExifTool Version Number      : 13.44
File Name                    : report3_medi.pdf
Directory                    : .
File Size                    : 2.9 kB
File Modification Date/Time   : 2026:09:12 18:51:58+05:30
File Access Date/Time        : 2026:09:12 18:51:58+05:30
File Inode Change Date/Time   : 2026:09:12 18:51:58+05:30
File Permissions              : -rw-rw-r--
File Type                    : PDF
File Type Extension           : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.4
Linearized                   : No
Author                       : j.malik
Comments                     : DB backup moved to /old before site migration, do not delete
Creator                      : Mediroza CMS 1.4.2
Keywords                     : pathology, patient report
Producer                     : Mediroza Lab Reporting Module
Subject                       : Full Blood Count
Title                        : Pathology Report - E. Thompson
Page Count                   : 1
```

Directory listing is a web server misconfiguration that displays the contents of a folder like a file browser when no index page exists. The /old folder on the server had directory listing enabled, exposing a

database backup file to anyone who visited that URL. I had already found this folder during my initial recon from the robots.txt file, which listed it as a disallowed path.

The directory listing was enabled and I could see the backup file immediately: mediroza_db_backup_2019.sql. I downloaded it using wget.

```
wget https://medirozahospital.com/old/mediroza_db_backup_2019.sql
```

Confidential Staff Salaries and Shareholder Data in Plain Text

The database backup contained highly sensitive information in plain text including the full name, job title, department, email address, phone number, national ID number, and monthly salary for hospital employees. It also contained the names and shareholding percentages of the hospital's shareholders. This data was completely unprotected and accessible to anyone who visited the /old folder.

SQL file in a text editor. The data was in raw SQL format, containing INSERT INTO statements for the staff and shareholders tables.

```
-- Dumping data for table `staff`
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff`
(`id`, `full name`, `job title`, `department`, `email`, `phone`, `national_id`, `monthly_salary_zar`, `date_joined`)
VALUES
(1, 'Dr. Rajesh Naidoo', 'Chief Pathologist', 'Diagnostics Lab', 'r.naidoo@medirozahospital.com', '+27 82 101
2007', '85021013011081', 138000, '2009-03-16'),
(2, 'Sarah Botha', 'Chief Financial Officer', 'Finance', 's.botha@medirozahospital.com', '+27 82 102
2014', '85031023022082', 152000, '2011-07-01'),
(3, 'Dr. Johan van der Merwe', 'Medical Director', 'Management', 'j.merwe@medirozahospital.com', '+27 82 103
2021', '85041033033083', 160000, '2007-01-22'),
(4, 'Dr. Anita Naicker', 'Consultant Cardiologist', 'Cardiology', 'a.naicker@medirozahospital.com', '+27 82 104
2028', '85051043044084', 132000, '2012-09-10'),
(5, 'Dr. Ahmed Kara', 'Consultant Physician', 'Internal Medicine', 'a.kara@medirozahospital.com', '+27 82 105
2035', '85061053055085', 128000, '2013-02-18'),
(6, 'Dr. Yusuf Cassim', 'Senior Registrar', 'Emergency & Trauma', 'y.cassim@medirozahospital.com', '+27 82 106
2042', '85071063066086', 74000, '2018-05-04'),
(7, 'Michael Roberts', 'HR Director', 'Human Resources', 'm.roberts@medirozahospital.com', '+27 82 107
2049', '85081073077087', 96000, '2010-11-15'),
(8, 'Susan Pretorius', 'HR Officer', 'Human Resources', 's.pretorius@medirozahospital.com', '+27 82 108
2056', '85091083088088', 32000, '2016-08-23'),
(9, 'Jameel Malik', 'IT Systems Administrator', 'IT', 'j.malik@medirozahospital.com', '+27 82 109
2063', '85101093099080', 58000, '2015-04-12'),
(10, 'Thabo Molefe', 'Network Engineer', 'IT', 't.molefe@medirozahospital.com', '+27 82 110
2070', '85111103110081', 46000, '2017-10-02'),
(11, 'Nomvula Khumalo', 'Registered Nurse', 'Emergency & Trauma', 'n.khumalo@medirozahospital.com', '+27 82 111
2077', '85121113121082', 34000, '2016-01-19'),
(12, 'Lerato Mokoena', 'Registered Nurse', 'Pediatrics', 'l.mokoena@medirozahospital.com', '+27 82 112
2084', '85011123132083', 33000, '2017-06-07')
```

I used AI-assisted analysis to convert the raw INSERT INTO rows for both the staff and shareholders tables into clean, readable tables for this report.

I was able to read the private salary of every employee and the ownership structure of the entire hospital. I also confirmed that the Author field in the PDF metadata, j.malik, corresponds to Jameel

Malik, the IT Systems Administrator listed in the staff table. This connects all three milestones in a single attack chain.

5. Risk Analysis / Impact

Based on the information collected activities, I identified the following potential risks.

#	Risk / Finding	Potential Impact	Risk Level
1	SQL Injection Authentication Bypass	Total compromise of portal access control	Critical
2	Cryptographic Weakness in PDFs	Provides information about the network location of the web service	High
3	Crawler Directive Path Disclosure	May assist technology fingerprinting and further enumeration	● Low
4	Unsanitized PDF Document Metadata	Reveals information about the web application's security architecture	● Medium
5	Open Directory Index & SQL Dump Leak	DNS information can help build a broader infrastructure profile	Critical

Risk level key: ● Critical ● Medium ● Low

6. Recommendations and Remediation

The following recommendations and remediation need to be followed:

- Change the login page to show a single generic message for any failed login attempt, regardless of whether the username or password was wrong. For example: "Invalid credentials. Please try again."
- Replace the current login query with a parameterised query or prepared statement. This separates the SQL code from the user input so that no amount of crafted input can change the query structure. This is the most important fix in this report.
- Move the PDF files outside the web root so they cannot be served directly by the web server. Enforce access through a server-side script that checks authentication before serving any file. If passwords are used, enforce a minimum length of 12 characters with a mix of uppercase, lowercase, numbers, and symbols.
- Remove all metadata from files before distributing them. Staff notes or internal comments must never be stored inside files that leave the organisation.
- Disable directory listing on all folders by adding Options -Indexes to the Apache configuration or .htaccess file. Delete the database backup from the /old folder immediately. Database backups must never be stored inside the web root. Store them in a private, access-controlled location outside the publicly accessible part of the server.

7. Conclusion

The penetration testing assessment identified seven security vulnerabilities, including multiple Critical and High-risk issues. The findings demonstrated that weaknesses in authentication, SQL injection protection, file access controls, PDF security, and server configuration could lead to unauthorised access to sensitive patient, employee, and organisational data.

Overall, the application has a Critical security risk and requires immediate remediation, particularly for the SQL injection, exposed database backup, and sensitive data exposure. A follow-up security assessment should be conducted after remediation to verify that the identified vulnerabilities have been properly addressed